Tường lửa và phân vùng truy cập

Tài liệu học tập chi tiết · Lý thuyết, ví dụ, thực hành và hướng giải

Vị trí bài học trong khóa

- Khóa học: Mạng máy tính cơ bản.
- Chương 5: Giao vận và vận hành an toàn.
- Các bài trong chương: Cổng, socket và vòng đời kết nối TCP; Tường lửa và phân vùng truy cập.
- Đọc lý thuyết, tự làm ví dụ rồi đối chiếu hướng giải; sau đó mới làm quiz. Bài thực hành tổng hợp cuối khóa dùng để kết nối kiến thức giữa các chương.

Mục tiêu bài học

Đề xuất chính sách truy cập tối thiểu trong một mạng lab.

Kiến thức nền

Tường lửa cho phép hoặc chặn lưu lượng theo chính sách như IP, cổng, giao thức và trạng thái kết nối. Chính sách nên xuất phát từ luồng nghiệp vụ cần thiết thay vì mở mọi cổng để thử. Stateful firewall theo dõi trạng thái để xử lý lưu lượng phản hồi phù hợp.

Phân vùng đặt thiết bị có nhu cầu và mức tin cậy khác nhau vào vùng riêng. Mạng khách thường chỉ cần Internet, không cần truy cập máy chủ quản trị nội bộ. Quyền tối thiểu nghĩa là chỉ cấp truy cập cần cho công việc, rồi kiểm tra cả luồng được phép và luồng phải bị chặn.

Ghi log có ích nhưng phải tránh lưu mật khẩu và token. Thay đổi chính sách cần kế hoạch khôi phục, đặc biệt nếu đang quản trị từ xa. HTTPS bảo vệ đường truyền, tường lửa kiểm soát luồng; hai công cụ không thay thế nhau. Không tiến hành quét hoặc thử vượt quyền trên mạng bên ngoài phạm vi được cho phép.

1. Chuyển yêu cầu thành chính sách

Lập danh sách tài sản, vùng, người dùng và luồng nghiệp vụ trước. Mỗi quy tắc cần nguồn, đích, giao thức, cổng hoặc dịch vụ, hành động và lý do. Thứ tự xử lý và mặc định phụ thuộc nền tảng; phải hiểu cơ chế đang dùng thay vì chép cấu hình từ thiết bị khác.

2. Ví dụ ma trận truy cập

```
Nguồn      Đích              Nhu cầu           Quyết định
Student    LMS               HTTPS             Cho phép
Guest      Vùng quản trị     Mọi dịch vụ        Từ chối
```

```
Admin       Máy lab quản trị     Kênh quản trị chọn    Cho phép có giới hạn
Student     DNS resolver nội bộ  DNS                   Theo thiết kế
```

Ma trận là mô hình lab. Không mặc định nó đã bao phủ mọi lưu lượng cần cho một hệ thống thật. Nêu DNS, đồng bộ giờ và các phụ thuộc nếu ứng dụng yêu cầu.

3. Thực thi và kiểm chứng

Sao lưu cấu hình; có đường khôi phục; áp dụng thay đổi nhỏ; kiểm tra luồng được phép và luồng bị cấm; so sánh log với nguồn/đích thực tế. Lọc theo hướng sai hoặc gắn sai interface có thể khiến quy tắc đúng trên giấy nhưng không có hiệu lực.

Stateful firewall theo dõi phiên để xử lý lưu lượng liên quan, nhưng không tự hiểu đúng mọi yêu cầu nghiệp vụ. WAF, firewall mạng và phân quyền ứng dụng giải quyết các phạm vi khác nhau.

4. Bài tập có tiêu chí chấm

Viết sáu quy tắc cho mạng lớp học và giải thích từng quy tắc. Chọn một thay đổi có thể khóa quản trị từ xa, mô tả cách hoàn nguyên không phụ thuộc phiên đang bị ảnh hưởng. Đáp án đạt cần tối thiểu quyền, không để mật khẩu trong log và có ca thử âm; chỉ nói ping được chưa đủ.

> **Bài tập vận dụng bổ sung**
>
> Viết bảng nguồn, đích, giao thức/cổng và quyết định cho ba luồng: học viên mở web, khách vào trang quản trị nội bộ, quản trị viên kết nối máy lab. Ghi cách kiểm tra và hoàn nguyên.

Hướng giải bài tập bổ sung

Không chỉ kiểm tra có thể truy cập web; cần xác nhận khách bị chặn đúng vùng. Không dùng việc NAT hoạt động để kết luận chính sách đã an toàn.

Câu hỏi tự kiểm tra

1. Nguyên tắc quyền tối thiểu là gì?
2. Stateful firewall theo dõi thông tin gì?
3. Kiểm tra chính sách mạng khách nên bao gồm gì?
4. Khi sửa firewall từ xa cần chuẩn bị gì?
5. Thông tin nào không nên ghi vào log?

Gợi ý đáp án và điểm cần nhớ

- Chỉ cấp truy cập cần thiết cho nhiệm vụ. Quyền được giới hạn theo nhu cầu thực tế.
- Trạng thái kết nối. Trạng thái giúp áp dụng chính sách cho lưu lượng liên quan phiên.
- Cả truy cập được phép và bị chặn. Cần xác nhận cho phép và từ chối đều đúng.
- Kế hoạch khôi phục truy cập. Quy tắc sai có thể khóa chính người quản trị.

- Mật khẩu và token. Bí mật xác thực cần được loại khỏi nhật ký.

Cách tự đánh giá sau bài

- Giải thích được thuật ngữ mà không đọc lại định nghĩa.
- Thực hiện lại ví dụ với dữ liệu khác và nêu được giới hạn áp dụng.
- Hoàn thành bài tập, đối chiếu bằng chứng hoặc đầu ra với hướng giải.
- Nếu còn nhầm, ghi câu hỏi cụ thể để hỏi giảng viên hoặc AI Tutor cùng ngữ cảnh bài.

Các câu tự kiểm tra có thể trùng trọng tâm quiz. Làm đúng câu đã đọc không tự chứng nhận thành thạo; cần thêm bài vận dụng và minh chứng thực hành.

Tài liệu đọc thêm

- https://www.netacad.com/courses/networking-basics
- https://developer.mozilla.org/en-US/docs/Web/HTTP

Tường lửa và phân vùng truy cập — Thực hành và hỏi đáp

Phần bổ sung cho bài học · biên soạn 29/10/2026

Tình huống, ví dụ và tự kiểm tra

Tình huống: muốn chỉ học viên truy cập web, không truy cập database. Xác định nguồn, đích, port và chiều kết nối; cho phép đúng luồng cần dùng. Backend truy cập DB theo quyền riêng, không mở DB cho mọi client.

Tự luyện: viết ma trận luồng học viên→web, web→API, API→DB. **Hướng giải:** kiểm tra cả luồng hợp lệ và luồng bị cấm trong lab. Không tắt toàn bộ firewall rồi coi lỗi đã được sửa; chính sách cần lưu và có cách hoàn tác.

Nguồn học tiếp

https://www.rfc-editor.org/rfc/rfc9293.html